

Nessus Vulnerability Assessment

End-to-End Linux Infrastructure Security Evaluation:
Credentialed Scanning, CVE Analysis, and Ansible-Driven
Remediation on Kali Linux with Nginx 1.15.5

94

Vulnerabilities Detected
(Credentialed Scan)

8

CVE Groups Identified
on Nginx 1.15.5

100%

Remediation Rate
via Ansible Playbook

1.28.0

Nginx Patched Version
from 1.15.5

Ejoke John Oghenekewe

Cybersecurity Analyst | SOC Engineer

ejoke.john4socanalyst@outlook.com

[linkedin.com/in/john-ejoke](https://www.linkedin.com/in/john-ejoke) | github.com/john-ejoke

Kali Linux | Nessus Essentials 10.9.4 | Ansible Core 2.19.2

This report documents a complete vulnerability management lifecycle on a Kali Linux host running a deliberately deployed legacy Nginx installation. A credentialed Advanced Scan over SSH surfaced **94 vulnerabilities**. A Web Application Tests scan against Nginx 1.15.5 identified 4 High and 4 Medium CVE groups (CVSS 5.3–7.7), with two public exploits. All vulnerabilities were remediated via a single Ansible playbook. Nginx patched from 1.15.5 to 1.28.0, **100% remediation rate confirmed**.

94 Total Vulns	7 Distinct CVEs	2 Public Exploits	100% Remediation
-------------------	--------------------	----------------------	---------------------

ASSESSMENT SCOPE PROJECT PARAMETERS	
Parameter	Detail
Target Host	Kali Linux (Rolling), IP 10.0.3.3, Linux Kernel 6.12.25-amd64
Scanner	Tenable Nessus Essentials 10.9.4
Scan Types	Credentialed Advanced Scan + Web Application Tests
Credentials	SSH username/password, port 22, OpenSSH_3.5.3 client
Vulnerable Service	Nginx 1.15.5 compiled from source (deliberate legacy deployment) legacy deployment
Severity Scoring	CVSS v3.0 throughout, set in both scan configurations
Remediation	Ansible Core 2.19.2, single playbook, zero failures
Reporting	Gmail SMTP, smtp.gmail.com:587, Force TLS, App Password
Frameworks	NIST SP 800-40, ISO/IEC 27001, NIST CSF, CVSS v3.0

PIPELINE OVERVIEW ASSESSMENT PHASES	
1	Environment Preparation OpenSSH installed and enabled on boot. Nessus 10.9.4 installed via dpkg. All cryptographic self-tests passed. Dashboard confirmed active at localhost:8834.
2	Credentialed Advanced Scan SSH credentials configured in Nessus Credentials tab. Full authenticated scan of 10.0.3.3 completed in 16 minutes. Auth: Pass confirmed. 94 vulnerabilities surfaced.
3	Vulnerable Service Deployment Nginx 1.26.3 removed via apt. Nginx 1.15.5 compiled from source. Initial scan on 1.26.3 confirmed zero high/medium findings, validating the deliberate downgrade.
4	Web Application Tests Scan 18-minute scan against 10.0.3.3 returned 11 findings: 4 High, 5 Medium, 2 Info, mapping to 4 CVE groups covering 7 distinct CVEs.
5	Automated Email Reporting Nessus SMTP configured with Gmail App Password and Force TLS. 2-Step Verification active. Test email confirmed delivered end-to-end in analyst inbox.
6	Ansible Remediation Playbook executed: 0 failures, 0 unreachable. Nginx patched to 1.28.0. All 7 CVEs resolved. Remediation rate: 100%.

CVE SUMMARY

ALL IDENTIFIED CVEs

CVE	Severity	CVSS v3.0	Plugin ID	Exploit	Status
CVE-2021-23017	High	7.7	150154	Yes	Patched
CVE-2019-9511	High	7.5	127907	No	Patched
CVE-2019-9513	High	7.5	127907	No	Patched
CVE-2019-9516	High	7.5	127907	No	Patched
CVE-2018-16843	Medium	6.1	118956	No	Patched
CVE-2018-16844	Medium	6.1	118956	No	Patched
CVE-2018-16845	Medium	6.1	118956	No	Patched
CVE-2019-20372	Medium	5.3	134220	Yes	Patched

DETAILED ANALYSIS

CVE DEEP DIVES

CVE-2021-23017: nginx Resolver 1-Byte Memory Overwrite (RCE)

HIGH CVSS 7.7 Plugin 150154 EXPLOIT PUBLIC PATCHED in 1.20.1

Memory corruption in the Nginx resolver module. An unauthenticated attacker sends a crafted DNS response causing a 1-byte overwrite, resulting in worker crash or arbitrary code execution. Resolver must be enabled in nginx.conf. Patch: May 25, 2021 - this version was nearly three years behind.

CVE-2019-9511 / CVE-2019-9513 / CVE-2019-9516: HTTP/2 Multiple Denial of Service

HIGH CVSS 7.5 each Plugin 127907 NO PUBLIC EXPLOIT PATCHED in 1.16.1

Three DoS vulnerabilities in the HTTP/2 stack. CVE-2019-9511 uses window size and stream priority manipulation for CPU/memory exhaustion. CVE-2019-9513 shuffles stream priorities to exhaust resources. CVE-2019-9516 sends zero-length headers to crash the server. All three require only network access. Patch: August 13, 2019.

CVE-2018-16843 / CVE-2018-16844 / CVE-2018-16845: HTTP/2 and MP4 Resource Exhaustion

MEDIUM CVSS 6.1 each Plugin 118956 NO PUBLIC EXPLOIT PATCHED in 1.14.1

CVE-2018-16843 and CVE-2018-16844 affect ngx_http_v2_module causing excessive memory and CPU consumption. CVE-2018-16845 affects ngx_http_mp4_module and can crash worker processes or disclose memory. Under sustained attack these produce effective denial of service. Patch: November 6, 2018.

CVE-2019-20372: Information Disclosure via HTTP Request Smuggling

MEDIUM CVSS 5.3 Plugin 134220 EXPLOIT PUBLIC PATCHED in 1.17.7

When Nginx is configured with certain error_page directives behind a load balancer, an attacker can smuggle a secondary HTTP request to read pages that should be inaccessible. Practical impact in production with a load balancer is significant. Sensitive internal pages become readable without authorization. Patch: December 24, 2019.

RISK MATRIX	
RISK BY LIKELIHOOD AND IMPACT	
CRITICAL RISK CVE-2021-23017: RCE with public exploit Likelihood: High Impact: High	HIGH RISK CVE-2019-9511 CVE-2019-9513 CVE-2019-9516 HTTP/2 DoS Likelihood: Medium Impact: High
MODERATE RISK CVE-2018-16843 CVE-2018-16844 CVE-2018-16845 Resource exhaustion Likelihood: Medium Impact: Medium	LOW RISK CVE-2019-20372: HTTP request smuggling Likelihood: Low Impact: Medium

ANSIBLE IAC

REMEDIATION: ANSIBLE PLAYBOOK

All vulnerabilities were remediated via a single Ansible playbook. It removes source-compiled Nginx 1.15.5, refreshes package lists, installs the latest stable version, and ensures the service runs and is enabled on boot. Scales to any number of hosts without changes.

```
# update_nginx.yml | Author: Ejoke John Oghenekewe | Cybersecurity Analyst
# Usage: ansible-playbook update_nginx.yml --ask-become-pass
- name: Patch Nginx on Kali Linux
  hosts: localhost
  become: yes
  tasks:
    - name: Remove outdated Nginx if installed manually
      file:
        path: /usr/local/nginx
        state: absent
    - name: Ensure system package lists are updated
      apt:
        update_cache: yes
    - name: Install latest Nginx
      apt:
        name: nginx
        state: latest
    - name: Start and enable Nginx service
      systemd:
        name: nginx
        state: started
        enabled: yes
```

Execution Result

Task	Result	Detail
Gathering Facts	ok	localhost
Remove outdated Nginx if installed manually	changed	/usr/local/nginx removed
Ensure system package lists are updated	ok	Cache already current
Install latest Nginx	changed	nginx 1.28.0 installed from apt
Start and enable Nginx service	changed	Service started, enabled on boot
PLAY RECAP	ok=5 changed=3	failed=0 unreachable=0 skipped=0

VERIFICATION

After playbook execution, `nginx -version` returned `nginx version: nginx/1.28.0`. All 7 CVEs in this assessment are resolved in nginx 1.28.0. The source-compiled 1.15.5 was fully removed and replaced with package-manager-managed 1.28.0. Remediation rate: 100%.

SMTP AUTOMATION

AUTOMATED REPORTING CONFIGURATION

Nessus was configured to deliver scan results via Gmail SMTP with Force TLS. A Gmail App Password was generated with 2-Step Verification active, scoped to Nessus only and independently revocable from the main account. Force TLS was selected over standard TLS because standard TLS permits a plaintext fallback if TLS negotiation fails, which is unacceptable for a channel carrying vulnerability report data. With Force TLS, if encryption cannot be established, the connection is refused entirely rather than falling back to plaintext.

Setting	Value	Rationale
SMTP Host	smtp.gmail.com	Gmail relay, reliable and widely supported
Port	587	Standard STARTTLS submission port
Encryption	Force TLS	No plaintext fallback permitted under any condition
Authentication	App Password (16-char)	Limited scope, independently revocable
Trigger	On Completion	Fully automated, no manual check-in required

Enabling Scan Notifications

Once SMTP is confirmed working, open any saved scan in Nessus, click Configure, navigate to the Notifications section, add the recipient email address, and set the trigger to On Completion. From that point forward every completed scan automatically pushes a full vulnerability report to the configured inbox with no manual action required. This closes the reporting loop: findings are surfaced, delivered, and actioned without anyone needing to log into the Nessus dashboard to check. In a real SOC environment, scan results that stay inside the scanner are scan results that do not get acted on.

Complete Vulnerability Summary

The following table consolidates all eight CVEs identified across both scan types, their severity classifications, exploit availability, and remediation status following the Ansible playbook execution.

CVE	Severity	CVSS	Exploit	Category	Remediated In
CVE-2021-23017	High	7.7	Yes	RCE: Memory Overwrite	nginx 1.28.0
CVE-2019-9511	High	7.5	No	HTTP/2 DoS: CPU/Memory	nginx 1.28.0
CVE-2019-9513	High	7.5	No	HTTP/2 DoS: Priority Churn	nginx 1.28.0
CVE-2019-9516	High	7.5	No	HTTP/2 DoS: Header Crash	nginx 1.28.0
CVE-2018-16843	Medium	6.1	No	HTTP/2 Memory Exhaustion	nginx 1.28.0
CVE-2018-16844	Medium	6.1	No	HTTP/2 CPU Exhaustion	nginx 1.28.0
CVE-2018-16845	Medium	6.1	No	MP4 Module Memory Leak	nginx 1.28.0
CVE-2019-20372	Medium	5.3	Yes	HTTP Request Smuggling	nginx 1.28.0

PRODUCTION GUIDANCE

REMEDIATION RECOMMENDATIONS

IMMEDIATE ACTIONS | 30 DAYS

- Deploy Nessus or Tenable.io with credentialed scanning enabled across all production hosts
- Alert on any web server running a version older than the current stable release
- Establish Ansible or equivalent IaC tooling for consistent, auditable patch deployment
- Audit all Nginx deployments for source-compiled instances not managed by a package manager

SHORT TERM | 90 DAYS

- Schedule monthly authenticated vulnerability scans with automated email delivery
- Integrate Nessus findings into a SIEM such as Splunk or Microsoft Sentinel for event correlation
- Document a formal patch SLA: Critical 7 days, High 30 days, Medium 90 days
- Implement SSH key-based authentication for Nessus scanning in place of password credentials

LONG TERM | 6 MONTHS

- Build a continuous vulnerability management programme aligned with NIST SP 800-40 and ISO/IEC 27001 A.12.6
- Implement configuration baselines using CIS Benchmarks for Linux and Nginx
- Conduct quarterly penetration tests to validate that patched vulnerabilities are genuinely remediated
- Expand Ansible playbook coverage to all production hosts, version-controlled in a dedicated repository

GOVERNANCE ALIGNMENT

FRAMEWORKS REFERENCED

Framework	Application in This Project
NIST SP 800-40	Patch management lifecycle. Credentialed scanning, CVE triage, and Ansible deployment map to the Identify, Prioritize, and Deploy phases.
ISO/IEC 27001	Vulnerability management as Control A.12.6. Automated reporting satisfies monitoring and measurement requirements under Annex A.
NIST CSF	All five functions: Identify (asset inventory), Protect (hardening), Detect (Nessus), Respond (Ansible remediation), Recover (post-patch validation).
CVSS v3.0	All eight CVEs scored and prioritised. Severity Base set to CVSS v3.0 in both scan configurations throughout the assessment.
CIS Benchmarks	Referenced for long-term Linux and Nginx configuration baselines; the logical follow-on after remediation is confirmed.

KEY LESSONS

TECHNICAL TAKEAWAYS

AUTHENTICATED SCANNING IS NON-NEGOTIABLE

The gap between unauthenticated and credentialed scan results is enormous. This assessment returned 94 vulnerabilities with credentials. Without them, the scanner sees only open ports and banners; the majority of the risk surface stays invisible. Any programme using only unauthenticated scans is flying partially blind.

OLD SOFTWARE DOES NOT STAY QUIETLY VULNERABLE

The CVEs on Nginx 1.15.5 are not theoretical. They carry CVSS scores above 7.0, some have public exploits, and they have been known for years. Every day a production system runs unpatched software with documented CVEs is a day that risk is active and measurable.

AUTOMATION IS THE CORRECT ANSWER TO SCALE

Writing an Ansible playbook took more time than running apt upgrade nginx manually. But the playbook is repeatable, auditable, version-controlled, and deployable to any number of hosts. That investment pays back immediately at any scale beyond one machine.

CONTACT
AUTHOR

Ejoke John Oghenekewe | Cybersecurity Analyst | SOC Engineer

Email

ejoke.john4socanalyst@outlook.com

LinkedIn

linkedin.com/in/john-ejoke

GitHub

github.com/john-ejoke

PROJECT REPOSITORY
GITHUB DOCUMENTATION

The full project is published on GitHub at github.com/john-ejoke/john-ejoke/tree/main/Vulnerability_Management/nessus-vulnerability-assessment. The repository contains every artefact produced during this assessment including the Ansible remediation playbook, SMTP configuration reference, all 33 annotated screenshots mapped to their README references, and this executive report.

File / Folder	Contents
README.md	Full project walkthrough with all phases, CVE analysis, and technical decisions
update_nginx.yml	Ansible playbook: remove Nginx 1.15.5, install 1.28.0, enable service
docs/ossec-smtp-config.md	Nessus SMTP configuration reference with troubleshooting guide
screenshots/	33 annotated screenshots covering every phase from SSH setup to patch verification

FRAMEWORKS APPLIED
GOVERNANCE AND STANDARDS ALIGNMENT

NIST SP 800-40 guided the patch management lifecycle: identify vulnerable components, prioritise by CVSS score and exploit availability, plan remediation, deploy via Ansible, and verify. **ISO/IEC 27001 Control A.12.6** frames vulnerability management as a formal information security control; automated scanning and reporting satisfy its monitoring requirements. **NIST CSF** maps across all five functions: Identify (asset and service inventory), Protect (SSH hardening, service configuration), Detect (Nessus credentialed and web application scanning), Respond (Ansible playbook execution), and Recover (version verification and re-scan). **CVSS v3.0** was used to score and prioritise all eight findings throughout. **CIS Benchmarks** for Linux and Nginx are referenced in the long-term recommendations as the baseline hardening target once all CVEs are confirmed remediated.

Built in a controlled lab environment. All findings are real. All fixes are documented and verified. October 2025.